

MandirMitra Security Audit Report

Prepared For: MandirMitra Project

Prepared By: Security Review Analysis

Year: 2026

1. Executive Summary

MandirMitra is a temple management and accounting platform handling devotee data, donations, accounting records, and operational temple workflows. Due to the financial and personal data involved, the platform must adhere to high security standards. This report outlines current risk areas and recommended remediation steps.

2. Risk Assessment Overview

Category	Risk Level	Impact
Authentication	High	Unauthorized access to admin accounts
RBAC	High	Financial data manipulation risk
Secrets Management	Critical	Database compromise risk
Input Validation	Medium	Injection vulnerabilities
Rate Limiting	Medium	Brute-force attacks
Backup Strategy	Critical	Permanent data loss

3. Security Recommendations

- Implement OAuth2 with JWT and refresh token rotation.
- Enforce Role-Based Access Control (Admin, Accountant, Priest, Viewer).
- Remove all hardcoded secrets and migrate to environment variables or secret managers.
- Enable rate limiting on login and sensitive endpoints.
- Add audit logging for financial and user actions.
- Enforce HTTPS and configure HSTS.
- Implement daily automated database backups.
- Enable dependency scanning (pip-audit, npm audit) in CI/CD pipeline.

4. Secure Coding Standards

- Validate all input using Pydantic schemas.
- Avoid raw SQL or NoSQL string-based queries.
- Implement structured exception handling to avoid stack trace leaks.
- Use hashed passwords with bcrypt or Argon2.
- Implement CSRF protection where applicable.

5. DevOps & Deployment Hardening

- Configure CI/CD with automated testing and security scanning.
- Separate development and production databases.
- Restrict MongoDB access using IP whitelisting.
- Enable monitoring and logging alerts.
- Perform periodic penetration testing.

Conclusion: MandirMitra has a strong architectural foundation but requires structured security hardening to achieve enterprise-grade resilience. By implementing the above recommendations, the system can significantly reduce its attack surface and ensure long-term operational trust.